

Controles De Seguridad

Objetivo

Definir e implementar controles de seguridad alineados a los riesgos identificados mediante la metodología OCTAVE Allegro, con el fin de reducir su probabilidad de ocurrencia y/o minimizar su impacto en la organización.

Enfoque de selección de controles

Los controles de seguridad fueron definidos considerando:

- El nivel de riesgo (crítico, alto, medio)
- El tipo de amenaza identificada
- Las vulnerabilidades detectadas en la organización
- La viabilidad de implementación en el contexto de NovaTech Solutions

Se priorizan aquellos controles orientados a riesgos críticos y altos, debido a su impacto directo en la operación, reputación y cumplimiento legal.

Controles asociados a riesgos críticos

AM-05 — Inyección de código malicioso en producción

Tipo de riesgo: Integridad del software

- Preventivos:
 - Implementación de revisiones obligatorias de código (code review)
 - Protección de ramas principales (branch protection)
 - Uso de herramientas de análisis estático de código (SAST)
- Detectivos:
 - Monitoreo de cambios en repositorios
 - Alertas ante modificaciones no autorizadas
- Correctivos:
 - Reversión de cambios maliciosos
 - Auditoría del repositorio afectado

AM-07 — Ransomware en servidores

Tipo de riesgo: Disponibilidad / pérdida de información

- Preventivos:
 - Implementación de soluciones EDR
 - Segmentación de red
 - Políticas de actualización y parches
- Detectivos:
 - Monitoreo de comportamiento anómalo en servidores
 - Alertas de actividad sospechosa
- Correctivos:
 - Restauración mediante respaldos cifrados
 - Activación del plan de continuidad del negocio

AM-04 — Acceso no autorizado a repositorios

Tipo de riesgo: Acceso indebido

- Preventivos:
 - Implementación de autenticación multifactor (MFA)
 - Gestión de accesos basada en roles
 - Cierre automático de sesiones
- Detectivos:
 - Monitoreo de accesos y registros
 - Alertas por accesos desde ubicaciones inusuales
- Correctivos:
 - Bloqueo de cuentas comprometidas
 - Revisión de permisos

AM-01 — Extracción de base de datos de clientes

Tipo de riesgo: Confidencialidad / legal

- Preventivos:
 - Implementación de firewall de aplicaciones web (WAF)
 - Cifrado de datos en reposo y en tránsito
 - Control de accesos basado en roles
- Detectivos:
 - Monitoreo de consultas a la base de datos
 - Alertas de comportamiento anómalo
- Correctivos:
 - Contención del acceso
 - Notificación del incidente conforme a normativa

AM-03 — Phishing y robo de credenciales

Tipo de riesgo: Acceso no autorizado

- Preventivos:
 - Autenticación multifactor
 - Capacitación continua al personal
 - Configuración de SPF, DKIM y DMARC
- Detectivos:
 - Monitoreo de accesos sospechosos
 - Alertas de inicio de sesión anómalo
- Correctivos:
 - Restablecimiento de credenciales
 - Investigación del incidente

Controles asociados a riesgos altos

AM-06 — Ataque DDoS

- Preventivos: Servicios anti-DDoS
- Detectivos: Monitoreo de tráfico
- Correctivos: Redirección y mitigación de tráfico

AM-02 — Envío accidental de datos

- Preventivos: Herramientas DLP + capacitación
- Detectivos: Monitoreo de correos
- Correctivos: Notificación y contención

AM-09 — Caída por mala configuración

- Preventivos: Gestión formal de cambios
- Detectivos: Monitoreo de disponibilidad
- Correctivos: Restauración de servicios

Controles asociados a riesgos medios

M-08 — Fraude interno

- Preventivos: Segregación de funciones
- Detectivos: Auditorías
- Correctivos: Investigación y sanción

AM-10 — Sesión activa en equipo compartido

- Preventivos: Cierre automático de sesión
- Detectivos: Registro de accesos
- Correctivos: Revocación de sesiones activas

Aplicación de defensa en profundidad

Los controles serán implementados bajo un enfoque de múltiples capas de seguridad:

- Nivel de usuario (autenticación, capacitación)
- Nivel de aplicación (validaciones, controles de código)
- Nivel de red (firewalls, segmentación)
- Nivel de datos (cifrado, respaldos)

Controles compensatorios

En aquellos casos donde no sea posible implementar controles óptimos, se adoptarán medidas alternativas como:

- Supervisión manual de accesos
- Restricciones adicionales en sistemas críticos
- Uso de VPN para accesos remotos